

Integrated Assurance Review

An OpenEMS energy resilience laboratory

Governance · Risk · Compliance · Audit

Prepared for: portfolio review — governance, risk, compliance, audit and technology functions
Prepared by: Berk Ozcan, BSc Computer Science, University of Leeds **Date of issue:** 9 September 2026 **Subject:** Energy Resilience Assurance Lab, tag v1.1.0, final commit-pinned evidence set **Version:** 1.0 **Evidence repository:** github.com/Berk-hub/energy-resilience-assurance-lab

This review is a portfolio piece. I built the laboratory under review and then assessed it using the working formats of four professional functions: an internal audit report, a risk report, a CAF-based compliance self-assessment and a governance review. Building and reviewing the same system is a self-review threat that professional standards treat as a limitation on assurance; that limitation is applied throughout rather than ignored. This document does not constitute an audit and should not be relied upon as one, and nothing in it is legal advice.

1. Opinion and summary

Question this review answers: does the laboratory's control framework support its stated assurance claim — that a defined local energy-control function continues in a controlled manner during loss of central connectivity and leaves sufficient evidence to understand the interruption and recovery — and is that claim reported honestly?

Consistent with common internal-audit practice, separate opinions are expressed on design and on operating effectiveness:

Aspect	Opinion
Design of the control framework	Reasonable assurance — a generally sound framework exists; some issues were identified which may put the achievement of objectives at risk
Operating effectiveness of controls	Limited assurance — significant gaps remain: nine of eleven controls have no operating-effectiveness evidence

Four findings were raised:

ID	Finding	Priority
1	Historical telemetry reconciliation unverified	High
2	No independent review	Medium
3	Weak marker matching in the automated reconciliation check	Low

ID	Finding	Priority
4	Repository history hygiene	Low / Advisory

Three controls were tested and found operating as expected for the recorded scope (section 5.6). Given the self-review threat described in section 3.3, no opinion in this report should be read as stronger than limited assurance overall.

The direction of travel is positive. Between v1.0.0 and v1.1.0 the repository added provision-level obligation records, a residual-risk register covering all twelve risks, an audit program covering all eleven controls, and — the item I consider most significant — a source-level root cause for the one criterion that had failed to reach a conclusion.

2. Background

2.1 The system under review

The laboratory models a fictional commercial energy site: simulated solar generation, a battery energy storage system, a grid meter and consumption, connected to OpenEMS Edge for local control, with a central OpenEMS Backend and an InfluxDB time-series store behind it. OpenEMS source is pinned to a single upstream commit ([189ac916](#)), and the built executables are recorded with SHA-256 digests, so every observation in the evidence set can be tied to an exact software revision.

The core experiment interrupted the Edge-to-Backend communication path using a controlled TCP relay, while the Edge, the Backend and the database all kept running. During the interruption the simulated operating conditions were changed twice, and the local balancing controller responded in both directions — 4,500 W of discharge when consumption exceeded generation, then 2,500 W of charge when the conditions were reversed — with grid power held at its 0 W target throughout.

2.2 The assurance claim and its criteria

The claim was decomposed into six success criteria before any experiment ran, with a strict aggregation rule: any criterion not supported prevents an overall supported result. Five criteria (measurements available, control continues, no unexplained transition, interruption observable, evidence time-orderable) are supported by direct test evidence. The sixth — recovery is understandable, including historical telemetry reconciliation — is INCONCLUSIVE, and so is the overall result. That classification is the project's most important feature from an assurance perspective, and this review treats it as such.

2.3 What matters most in this system

Ranked by consequence, the assets that drive the ratings in this review are: the local control function itself (a wrong control action affects the physical process); the evidence set (the project's conclusions are only as good as its evidence chain); central telemetry continuity (incident reconstruction depends on it); and the

software provenance chain (an unpinned build would sever every observation from the code that produced it).

3. Scope, methodology and limitations

3.1 Scope

The review covered the eleven controls in `data/controls.json`, the evidence under `evidence/`, the v2 model layer (obligations, findings, risk treatments, audit program), and the repository's automated validation, for the period 8–9 September 2026. It did not cover the upstream OpenEMS codebase beyond the resend mechanism, and no penetration testing, IAM testing or physical testing was performed. Those exclusions are not incidental: they match the boundaries the repository itself declares.

3.2 Methodology

Testing was full-inspection rather than sample-based. The population of recorded failure-injection runs is two — the initial run and the final reconciliation run — and both were examined in full, including their timestamps, connection-state transitions, channel values and hash records. Model cross-references were verified by executing the repository's own test suite (21 tests) and its validation CLI. Where a conclusion depends on upstream behaviour, the pinned source was read directly rather than inferred from observation; the root cause in Finding 1 rests on specific constants and scheduling logic in the upstream resend worker.

3.3 Independence and limitations

Preparation and review of everything in this document were performed by the same individual. Professional standards treat this as a self-review threat, and the repository's own operating model records every review as SELF_REVIEW rather than simulating independent sign-off. My findings are based upon and limited to the work performed on the dates stated; there might be weaknesses that did not form part of the programme of work, and control systems, however well designed, are affected by inherent limitations including management override. This report therefore provides a documented method and a practice artefact, not independent assurance.

4. Rating criteria

Ratings were fixed before the findings were written.

Priority	Definition	Expected action
High	Blocks the project's central claim, or would mislead a reader of the assurance result if left unstated	Corrective action defined and tracked before any upgrade of the affected result
Medium	A real structural weakness that limits the strength of conclusions but does not invalidate them	Address where practicable; disclose while open

Priority	Definition	Expected action
Low / Advisory	Hygiene or reliability issue with limited individual impact	Fix in normal course

Assurance opinions use the four-level convention common in UK practice (substantial / reasonable / limited / no assurance), applied separately to design and operating effectiveness.

5. Internal audit findings

5.1 Finding 1 — Historical telemetry reconciliation unverified (High)

Criteria. Control ENG-REC-007 requires that restoration of central connectivity includes sufficient reconciliation to explain the resulting telemetry state (success criterion SC-06).

Condition. Testing of the final recorded run identified that the Edge's `LastSuccessfulResend` channel remained null throughout the post-reconnection observation window, and the expected post-resend central query evidence was never captured. Reconnection itself was clearly evidenced; reconciliation was not.

Cause. The root cause was identified from the pinned upstream source. OpenEMS deliberately does not resend history immediately on reconnection: the resend worker schedules its run at five minutes plus a random delay of up to one hour (`DELAY_TRIGGER_TIME + MAX_RANDOM_DELAY`), a sensible fleet-protection design. The laboratory's observation window after reconnection was 48.8 minutes against a worst case of 65. A contributing factor is that the local history store (RRD4J) was enabled thirteen minutes before the final run, which limits what gap-detection could see.

Consequence. There is a risk that an operational event could not be fully reconstructed from central records. In a production context that would impair incident analysis and could affect regulatory reporting. It is important to state what was *not* found: no evidence of data loss exists — local history remained intact — so this is an evidence gap, not a proven failure.

Corrective action. Management should execute retest protocol EXP-02 with an observation window of at least 66 minutes and distinctive marker values, capturing the post-resend central query as evidence.

Management response: Agreed. The recovery control owner (role; person unassigned) will execute EXP-02 in the next laboratory session. Until then SC-06 remains INCONCLUSIVE, and the repository's assessment logic keeps the overall result INCONCLUSIVE automatically.

5.2 Finding 2 — No independent review (Medium)

Criteria. Control ENG-GOV-001 expects recorded review of material decisions; review must be independent of preparation to count as assurance.

Condition. All preparation, testing and review in the repository were performed by the same individual. No conclusion has received independent challenge.

Cause. Single-author project.

Consequence. No reliance can be placed on internal review as an assurance layer. Every conclusion, including those in this report, carries a self-review threat.

Corrective action. Management should obtain an independent technical review of the evidence chain for at least the primary scenario when practicable. **Management response:** Agreed in principle; recorded as GAP-GOV-OVERSIGHT, with SELF_REVIEW labelling maintained meanwhile — the repository's honesty mechanism is to name the limitation rather than to costume it.

5.3 Finding 3 — Weak marker matching in the reconciliation check (Low)

Condition. The automated SC-06 check verifies central backfill by substring-matching expected power values (for example "700") in query output. A value such as "5700" would also match, so the check can produce a false positive.

Consequence. Low impact today, because SC-06 currently cannot pass at all. But the check would be unreliable at exactly the moment it matters — during the EXP-02 retest — and a false positive there would corrupt the project's central result.

Corrective action. Management should select marker values that cannot collide as substrings, or match on delimited fields. **Management response:** Agreed; will be addressed as part of EXP-02 preparation.

5.4 Finding 4 — Repository history hygiene (Low / Advisory)

Condition. Review of the development history identified several commits with non-descriptive messages. Git history is a stated integrity anchor for the evidence manifest — the repository's own documentation notes that a rewritten manifest passes local verification, so the manifest's integrity rests on history and CI. That raises the documentation bar for the history itself.

Corrective action. Management should maintain descriptive commit messages and establish a clean public baseline. **Management response:** Agreed. The public repository was re-initialised at a clean v1.1.0 baseline before wider publication, and descriptive messages are required from that baseline onward. The development history preceding the baseline is disclosed here rather than silently discarded.

5.5 Matter arising, closed in period

The absence of an incident-notification tabletop was identified during the review period and addressed through exercise TTX-01, a desk-based walkthrough of the recorded outage against notification triggers, with a decision log and identified unknowns. The exercise record makes clear it demonstrates method, not real response capability.

5.6 Controls operating as expected

Audit reporting is not only findings. Three controls were tested and found operating for the recorded scope:

Control	What was verified	Evidence
ENG-CTL-004 local control resilience	Balancing responded in both directions during the outage; grid held at its target; no unexplained transition	Final reconciliation run record
ENG-SUP-008 provenance	Pinned commit and artefact hashes consistent between the lock file and the provenance capture; upstream working tree recorded clean	Upstream lock and provenance files
ENG-DAT-011 evidence integrity	SHA-256 manifest verified on every push; modified and missing evidence fail loudly in negative tests	Evidence manifest, CI workflow, tamper tests

The remaining controls conclude "design adequate, operating effectiveness not tested" in the audit program. I regard that sentence, written accurately eleven times, as a feature of the repository rather than a weakness of this report: one experiment does not make a control effective, and the project declines to pretend otherwise.

6. Risk report

The residual-risk register covers all twelve risks. Two register rules matter more than any individual score: no likelihood was reduced on the strength of a documented-but-untested control, and ordinal scores were never summed into a portfolio total. Where effectiveness evidence is absent, the residual position is recorded as unassessed — insufficient evidence is not a low-risk rationale.

Risk	Inherent	Residual position	Response
R-RES-001 loss of central connectivity	16 High	Reduced within tested scope — five of six criteria supported by run evidence	Treat
R-CTL-002 unexplained control transition	15 High	Partially assessed — none observed; manipulation untested	Treat
R-IAM-004 unauthorised privileged access	15 High	Unassessed — nothing exercised	Treat
R-CFG-008 uncontrolled configuration change	15 High	Partially assessed — traceability shown; process untested	Treat
R-DEP-011 loss of required measurement	15 High	Unassessed — planned experiment not yet run	Treat
R-TEL-003 misleading telemetry	12 High	Partially assessed	Treat
R-MON-005 insufficient event evidence	12 High	Partially assessed — run evidence time-orderable	Treat
R-SUP-006 unmanaged dependency	12 High	Partially assessed — provenance evidenced; vulnerability governance out of scope	Treat
R-REC-009 recovery without reconciliation	12 High	Unassessed — blocked on Finding 1; outside appetite	Treat (EXP-02)
R-PHY-007 physical loss of Edge	10 High	Unassessed — not testable in this laboratory	Treat

Risk	Inherent	Residual position	Response
R-GOV-012 unclear ownership	9 Medium	Partially assessed — applicability records exist; oversight gap open	Treat
R-DAT-010 weak data lineage	6 Medium	Reduced within tested scope	Treat

Against the appetite statements in the operating model, one risk is reported outside appetite on evidence rather than on absence of evidence: R-REC-009, because unverified recovery blocks any end-to-end recovery claim. It is linked to a live corrective action with a defined validation method, which is the state a risk committee would expect an outside-appetite risk to be in. No risk has been accepted, transferred or terminated, and the register enforces a rule worth naming: a risk acceptance, if one ever existed, could not convert an assurance result to supported.

7. CAF self-assessment

Assessed against the NCSC Cyber Assessment Framework v4.0 principles referenced in the obligations register. Two honesty notes first: no competent-authority target profile applies to a laboratory, so no profile deviation can be claimed or excused; and this extract assesses at principle level, whereas a real operator's submission assesses each contributing outcome against its indicators of good practice. Statuses use the five-value vocabulary from Ofgem's NIS guidance.

Ref	Principle	Status	Justification
B5	Resilient networks and systems	Partially Achieved	Resilience of the local control function to loss of one central dependency is demonstrated by direct test evidence — a specific, worthwhile resilience benefit, which is the bar Partially Achieved must meet. Achieved is not available: one dependency was exercised, and the shared-host common-cause limitation means resilience to broader failures is undemonstrated.
C1	Security monitoring	Partially Achieved	The interruption and restoration were observable and time-orderable from retained evidence. Coverage beyond the exercised path, and detection of security as opposed to failure events, were not assessed.
D1	Response and recovery planning	Partially Achieved	A recovery path exists, reconnection was evidenced and an incident-assessment tabletop has been performed. Recovery understanding is incomplete while reconciliation is unverified; on a strict single-shortfall reading this would justify Not Achieved, and the status should be revisited after EXP-02.
Others	—	Not yet assessed	In scope for a real entity; scheduled only insofar as the experiment backlog exercises them. Recording this avoids the false impression of a completed CAF assessment.

This is a point-in-time self-assessment using the author's judgement; rationale and evidence for each status are traceable to individual repository files, and no assurance is expressed as to operating effectiveness beyond the evidence cited.

Improvement plan extract, in the shape of a regulator-facing submission:

Ref	Linked outcome / finding	Action	Validation method	Target
IMP-01	D1 / Finding 1	Execute EXP-02 with a 66-minute-plus observation window	Technical testing; automated assessment re-run	Next laboratory session
IMP-02	Finding 2	Independent review of the primary evidence chain	Independent re-performance	When a reviewer is available
IMP-03	B5	Exercise a second dependency (stale meter input)	Technical testing	Backlog

8. Compliance and applicability

The obligations register records provision-level applicability for NIS2 Articles 20, 21 and 23, UK NIS Regulation 10 and the CAF principles above, against two explicitly fictional entity profiles — a GB operator assumed within the OES regime for analysis, and an EU entity whose member state is deliberately unselected.

Three disciplines in the register are worth an assessor's attention. First, the EU positions are assessed against the Directive as published; member-state transposition can add stricter requirements or different thresholds, so each record remains conditional with its missing facts listed, and each will need re-performance against national implementing measures if a real profile ever replaces the fictional one. Second, the requirement-is-engaged-where structure is applied consistently: nothing is marked not applicable for lack of information, which is the commonest quiet abuse of applicability registers. Third — and this rule is enforced in the repository's automated tests, not just stated — a mapping from a control to a regulatory provision is treated as a reason the provision matters, never as evidence of compliance with it.

The register's reporting obligation (Article 23) is supported by the TTX-01 tabletop, whose decision log concludes that on the recorded facts a 33-second monitoring-path interruption with no service disruption would plausibly be handled as an internal event rather than a notification — while recording the deciding uncertainty (the unverified backfill) and the facts that would change the answer.

9. Governance review

Decision rights, appetite statements and escalation expectations are documented in the operating model, with a decision table assigning preparation and accountability per decision type. The structural weakness is disclosed rather than dressed up: one person holds every role, segregation of duties does not exist, and every recorded review is a self-review.

The compensating discipline — the only one genuinely available to a single author — is that the models make dishonesty expensive. The results vocabulary is constrained to four values; unevidenced upgrades are blocked by automated tests; evidence tampering fails loudly, and the one tampering route that succeeds locally (rewriting the manifest itself) is documented in the test suite rather than hidden; and

open findings are published with owners and closure criteria rather than resolved by edit. Governance here is not a committee — it is a set of rules the repository physically enforces against its own author.

10. Conclusion and follow-up

The laboratory demonstrates the mechanics of an assurance-led operation at small scale: obligations traced to controls, controls to tests, tests to evidence, and gaps to owned actions — with the traceability enforced by software rather than promised by prose. What it cannot demonstrate, it says out loud: independence, operating effectiveness over time, physical and identity-layer resilience, and any regulatory relationship.

The single follow-up that matters is EXP-02. If the retest verifies central backfill within the scheduler's window, the last criterion moves to supported and the central claim closes; if it shows genuine loss, the project gains a finding worth having. Either outcome is acceptable to this reviewer; only the current unknown is not, and it is time-bound.

In my judgement the correct professional posture for a laboratory of this kind is exactly the one it takes: narrow claims, constrained vocabulary, published uncertainty, and limits stated in the same breath as results. The findings in this report are real, but none of them undermines that posture — three of the four exist precisely because the repository is honest enough to expose them.

Appendix A — Principal evidence referenced

File	Used in
evidence/backend-loss/11-final-reconciliation-run.json	Findings 1, 5.6; sections 2, 6
evidence/backend-loss/15-final-reconciliation-status.json	Finding 1
evidence/backend-loss/13-historic-resend-monitor.log	Finding 1
evidence/backend-loss/SHA256SUMS and CI workflow	Section 5.6
config/openems-upstream-lock.json, evidence/supply-chain/openems-provenance.json	Section 5.6
data/risks.json, data/risk-treatments.json	Section 6
data/obligations.json, data/entity-profiles.json	Sections 7, 8
data/audit-program.json, data/findings.json	Section 5
docs/11-operating-model.md, docs/12-dependency-resilience.md	Sections 6, 9
docs/13-sc06-root-cause.md	Finding 1
docs/15-ttx-notification.md	Sections 5.5, 8

Appendix B — Audit conclusions by control

Control	Design	Implementation	Operating effectiveness
ENG-GOV-001 applicability and ownership	Adequate	Partial	Not tested
ENG-ARC-002 architecture and dependencies	Adequate	Evidenced	Not tested
ENG-IAM-003 privileged access	Adequate	Not tested	Not tested
ENG-CTL-004 local control resilience	Adequate	Evidenced	Not tested (single scenario)
ENG-TEL-005 telemetry integrity	Adequate	Partial	Not tested
ENG-MON-006 logging and time	Adequate	Partial	Not tested
ENG-REC-007 recovery and reconciliation	Adequate	Blocked (Finding 1)	Not tested
ENG-SUP-008 provenance	Adequate	Evidenced	Not tested
ENG-PHY-009 physical dependencies	Adequate	Not tested — not testable here	Not tested
ENG-CFG-010 change traceability	Adequate	Partial	Not tested
ENG-DAT-011 evidence integrity	Adequate	Evidenced	Narrow (repeated CI verification)

Formats follow common UK practice: IIA-style finding anatomy and assurance opinion scales, Orange Book risk-response vocabulary, and the CAF/Ofgem self-assessment status vocabulary. Any errors of interpretation are the author's own.